Evidence-Labeled Threat Intelligence Assessment and SOC Defensive Guidance (2009 — March 2026).
Author: Andrey Pautov. Evidence cutoff: March 5, 2026. Original article (Medium).

CTI Research: Sandworm / APT44

Evidence-Labeled Threat Intelligence Assessment and SOC Defensive Guidance (2009 — March 2026)

Table of Contents

Report Metadata
Methodology & Evidence Labels
Confidence & What Changes Confidence
Executive Summary
Actor Overview
Alias / Cluster Crosswalk
Key Judgments
Attribution Assessment
Activity Timeline (2009–2026)
Confirmed vs Claimed Matrix
Targeting and Victimology
Operational Doctrine: Evolution
Initial Access and Privilege Escalation Patterns
Malware and Tooling Portfolio
Deep Technical Analysis of Key Families
Detection and Response Priorities
Detection Engineering Pack (SOC-Ready)
Wiper/OT First 30 Minutes (Defensive Mini-Playbook)
Controls Mapping (NIST CSF-Lite)
Common Patterns and Cross-Group Correlation
Collection Gaps and Unresolved Questions
Practical Defensive Actions (Next 30 Days)
Appendix A: IOC Compendium (Public Reporting)
Appendix B: ATT&CK-Oriented Mapping (Analyst View)
References

Report Metadata

- Analytic intent: Convert public-source reporting into evidence-labeled, SOC-actionable CTI.

- Evidence cutoff (collection freeze): March 5, 2026 (UTC)
- Assessment window: 2009 — March 2026
- Date: March 6, 2026
- Author: Andrey Pautov
- Document classification: Public-release CTI product. All sources are open and publicly available.

Methodology & Evidence Labels

This document uses five evidence labels applied consistently to every factual claim.

Observed means directly documented technical evidence in primary technical, government, or legal reporting — for example, malware behavior, sample metadata, protocol usage, or deployment mechanics.

Reported means described by reputable external sources with strong credibility but without full victim-side telemetry disclosure.

Assessed means analytic inference synthesized from multiple Observed or Reported items; it is not standalone proof.

Claimed means actor or persona assertions without sufficient independent technical corroboration.

Partially corroborated is used in the Confirmed vs Claimed section when at least one technical artifact exists but the complete incident kill-chain is not public. Press-only narratives do not qualify.

Analytic rule: Vendor naming overlap indicates cluster convergence, not guaranteed incident-level identity.

Confidence & What Changes Confidence

High confidence requires independent multi-source convergence across both technical and legal/government evidence.

Medium-High confidence reflects strong convergence with minor incident-level artifact gaps.

Medium confidence reflects partially convergent data with unresolved contradictions.

Low confidence applies to claim-led narratives lacking technical corroboration.

What increases confidence: victim telemetry, full malware samples, infrastructure reuse with temporal overlap, legal attribution, and corroborated OT forensics.

What decreases confidence: single-source claims, circular citation loops, and unresolved source conflicts.

Executive Summary

Mandiant formally designated Sandworm as APT44 on April 17, 2024. **[R1]** The cluster is assessed as one of the most capable and risk-tolerant cyber sabotage actors linked to the Russian military intelligence system — specifically the GRU Main Center for Special Technologies (GTsST — Главный центр специальных технологий), Military Unit 74455. The operational profile integrates espionage, destructive IT/OT disruption, and influence operations into a unified wartime playbook. **[R1][R2][R4][R9]**

Note on organizational structure: GTsST is a Centre (organizational unit) subordinate to the Main Directorate of the General Staff of the Armed Forces of the Russian Federation (GU), commonly referred to in the West as the GRU. The correct formal hierarchy is: GTsST → GU (Main Directorate) → General Staff. GTsST is not itself a "directorate."

Historically, the cluster has demonstrated repeated cyber-physical impact against energy infrastructure and broad collateral effects through destructive malware campaigns. Landmark operations include the Ukraine grid attacks (2015/2016), NotPetya (2017), the Olympic Destroyer operation (2018), and the April 2022 Industroyer2 attack chain. Wartime-era adaptation has emphasized edge-device access, Active Directory abuse, and wiper deployment tempo. **[R1][R2][R4][R6][R8][R9]**

Recent reporting (2024–2026) reveals four parallel trends:

- Influence-front integration: [Reported] Mandiant's September 2022 report initially assessed with moderate confidence that Telegram personas (XakNet Team, Infoccentr, CyberArmyofRussia_Reborn) coordinated with GRU-sponsored actors, with the supporting intrusion activity at that time attributed to APT28. In April 2024, Mandiant re-analyzed the incident data and re-attributed the relevant intrusion activity (formerly tracked as UNC3810) to APT44 with high confidence, after parsing overlapping APT28 and APT44 activity in the same network. Persona-level organizational affiliation with GRU operators remains moderate-confidence. **[R1][R25]**
- Expanded battlespace: Android military targeting (Infamous Chisel), Signal and Telegram message exfiltration from captured battlefield devices (WaveSign tool), drone supply-chain targeting, telecom-disruption tooling (AcidPour), Bellingcat attribution, and globally distributed access operations (BadPilot subgroup). **[R1][R10][R14][R28]**
- Tooling continuity with iteration: from Industroyer/Industroyer2 to Kapeka/KnuckleTouch (2022+), SwiftSlicer (2023), ZEROLOT (2024–2025), Sting, ZOV, DynoWiper, and LazyWiper (2025–2026), with code and logic overlap patterns in several cases. **[R16][R21][R22][R23][R27][R30]**

- Operational scaling through edge misconfiguration targeting: Amazon Threat Intelligence (December 2025) assessed with high confidence that a campaign active since at least 2021, consistent with Sandworm/APT44 tradecraft and infrastructure overlap, pivoted away from zero-day exploitation toward systematically targeting misconfigured customer network edge devices as primary initial access vectors. Credential harvesting via passive packet interception was the assessed collection method, with subsequent replay against victim online services. **[R29]**

Bottom line: APT44 remains a persistent, high-severity threat to critical infrastructure and strategic sectors globally. Defenders need architecture-level controls (edge, AD, OT segmentation) and behavior-based detection of administrative abuse — not IOC-only postures.

Actor Overview

Primary designation: Sandworm / APT44

Attribution core: GRU Main Center for Special Technologies (GTsST — Главный центр специальных технологий), Military Unit 74455, supported by legal and government attribution and long-horizon technical continuity. **[R4][R5][R9]**

Operational identity: Sabotage-forward, full-spectrum actor with demonstrated willingness to accept operational exposure for strategic impact.

Mission pillars (assessed):

1. Influence signaling and narrative amplification — persona ecosystem, public claims, information confrontation doctrine **[R1][R2][R9]**
2. Destructive and disruptive cyber operations — IT and OT, kinetically coordinated in select cases
3. Espionage and pre-positioning — access development, credential and network intelligence, battlefield targeting data

Alias / Cluster Crosswalk

APT44 is tracked under a large number of designations across vendors and government agencies. The following covers all publicly documented labels.

Sandworm Team — Historical/public label. Longstanding designation in government and vendor reporting. **[R4][R9]**

APT44 — Mandiant normalized cluster label. Formalized April 17, 2024. **[R1]**

Seashell Blizzard / IRIDIUM / Voodoo Bear — Vendor naming variants. Microsoft and cross-vendor alias ecosystem. **[R10][R24]**

FROZENBARENTS — Vendor naming variant. Used in Google/Mandiant internal tracking taxonomy alongside APT44; appears in cross-vendor correlation contexts. **[R1]**

Iron Viking — Vendor naming variant. Secureworks (CTU) tracking designation for overlapping Sandworm-era activity.

Quedagh — Historical label. Used by F-Secure (2014) in early BlackEnergy/Sandworm tracking context; one of the oldest documented aliases. Not widely used in current reporting.

Blue Echidna — Vendor naming variant. Dragos tracking designation for Sandworm/APT44 industrial-focused activity cluster.

TEMP.Noble — Vendor naming variant. Google/Mandiant internal pre-APT designation used in historical tracking before formal APT44 graduation. **[R1]**

UAC-0082 / UAC-0113 — CERT-UA tracking identifiers. Ukrainian CERT-UA identifiers for Sandworm-attributed activity clusters. Appear frequently in CERT-UA bulletins; critical for analysts working in Ukrainian operational context.

UAC-0125 / UAC-0133 — CERT-UA tracking identifiers. Additional CERT-UA cluster identifiers associated with Sandworm-adjacent activity in Ukrainian incident reporting.

Hades — Operation-level tracking label. Used by select vendors as a tracking label for the Olympic Destroyer operation (2018). Not a standalone threat actor designation in MITRE ATT&CK or most vendor frameworks — Mandiant now attributes the underlying activity to APT44. Does not imply a separate actor cluster.

Telebots / Electrum / BlackEnergy-era labels — Historical labels in vendor-era reporting. Associated in some reporting with overlapping Sandworm-era activity; not strict synonyms across vendor taxonomies. **[R8][R9][R15][R24]**

GTsST / Unit 74455 — Organizational attribution. GRU military unit designation tied to operations through legal and government sources. **[R4][R5][R9]**

Note: “Olympic Destroyer” is the name of the 2018 Winter Games disruption operation, not a standalone APT44 alias. Some vendors tracked it as a sub-cluster; Mandiant now attributes the underlying activity to APT44. **[R4][R8]**

[Assessed] Cross-vendor labels represent tracking-model differences around an overlapping operational ecosystem centered on GTsST/Unit 74455.

Key Judgments

KJ1 — APT44 is a full-spectrum military cyber actor. It blends access, disruption, and influence into one unified doctrine rather than operating as a pure espionage cluster. Confidence: High. **[R1][R2][R9]**

KJ2 — Cyber-kinetic synchronization is a recurring pattern. Reported operations repeatedly align with broader Russian military pressure windows (e.g., the October 2022 OT disruption coordinated with kinetic strikes on Ukraine's energy grid). Cyber-kinetic synchronization: the alignment of cyber disruption operations with conventional military actions to achieve combined operational effect. Confidence: High. **[R1][R3][R9][R12]**

KJ3 — Tradecraft has evolved toward scalable disruption. Edge compromise + Living-off-the-Land (LotL) + GPO deployment patterns reduce dependency on bespoke ICS/OT-layer malware per operation. Note: This refers specifically to reduced dependency on bespoke ICS/OT payloads. Bespoke IT-layer destructive tooling (wipers) continues to be developed, as addressed in KJ4. Confidence: High. **[R2][R10][R21][R29]**

KJ4 — Destructive capability remains active and iterating in 2025–2026. ZEROLOT/Sting/ZOV/DynoWiper/LazyWiper reporting indicates continued wiper development tempo; the tooling family is operationally iterative, not static. Confidence: Medium-High. **[R20][R21][R22][R23][R30]**

KJ5 — Attribution is strongest at cluster level; individual incidents may be contested. The December 2025 Poland event is a material case of inter-vendor attribution divergence. Confidence: Medium-High (cluster), Medium (incident-specific). **[R22][R23]**

KJ6 — Influence personas are an assessed support layer, not a proven command-integrated branch. "Telegraphing success" behavior can outpace forensic closure and force premature response decisions. Confidence: Medium. **[R1][R2][R25]**

KJ7 — Edge management exposure and weak identity controls remain high-leverage recurring weaknesses. Public incident data shows repeated reliance on exposed management interfaces, weak/default credentials, and absent MFA as initial enablers for high-impact sabotage chains. Confidence: High. **[R23][R26][R29]**

KJ8 — APT44 demonstrates a doctrinal shift toward tactical battlefield support. Since at least 2023, operations have included provisioning Signal/Telegram exfiltration infrastructure for Russian ground forces, drone supply-chain targeting, and battlefield device exploitation — a qualitative expansion beyond strategic disruption. Confidence: High. **[R1][R28]**

KJ9 — Criminal ecosystem integration is an established pattern. APT44 has increasingly sourced tools and bulletproof hosting infrastructure from criminal marketplaces, treating them as a disposable capability layer. Confidence: Medium-High. **[R1]**

Attribution Assessment

Attribution to the GRU Main Center for Special Technologies (GTsST — Главный центр специальных технологий), Military Unit 74455, is among the strongest in modern public cyber-intelligence for a destructive actor cluster.

Note: GTsST (Главный центр специальных технологий) is a Centre (organizational unit) within the Main Directorate of the General Staff of the Armed Forces of the Russian Federation (GU), commonly referred to in the West as the GRU. The correct formal structure is: GTsST → GU (Main Directorate) → General Staff. GTsST is not itself a "directorate" — it is a subordinate Centre within GU/GRU.

Attribution Pillars

Legal attribution: U.S. DOJ indictment (October 19, 2020) charging six Unit 74455 officers for multiple campaigns — Ukraine grid incidents, NotPetya, Olympic-related operations, and others. **[R4][R5]**

Government attribution convergence: UK statements and profiles repeatedly linking major incidents to Unit 74455/GTsST, including BlackEnergy, Industroyer, NotPetya, BadRabbit, the Georgia defacements, and Olympic Destroyer. **[R6][R7][R8][R9]**

Technical continuity: Malware and procedure lineage from BlackEnergy/Industroyer-era tradecraft through Kapeka, current destructive wiper families, and edge/LotL operational methods. **[R2][R13][R15][R16][R22][R27]**

Vendor convergence: Mandiant APT44 framing + Microsoft Seashell Blizzard tracking + ESET long-horizon destructive campaign evidence + Amazon Threat Intelligence 2025 campaign assessment. **[R1][R10][R20][R21][R22][R29]**

Legal Attribution Granularity (Observed)

The DOJ indictment **[R4]** names six GRU Unit 74455 officers tied to disruptive operations:

- Petr Nikolayevich Pliskin
- Artem Valeryevich Ochichenko
- Anatoliy Sergeyevich Kovalev
- Pavel Valeryevich Frolov
- Sergey Vladimirovich Detistov
- Yuriy Sergeyevich Andrienko

[Assessed] This level of public legal granularity materially strengthens attribution confidence versus vendor-only clustering, especially for long-horizon historical campaigns.

Important Caveat: Incident-Level Attribution

December 2025 Poland incident: ESET attributes DynoWiper to Sandworm with medium confidence; CERT Polska reports stronger overlap with infrastructure historically tracked as: Berserk Bear (CrowdStrike), Ghost Blizzard (Microsoft), Dragonfly / TEMP.Isotope (Symantec/Secureworks), and Static Tundra (less widely used). These labels represent different vendor tracking models for an overlapping activity cluster, not a single formally attributed group. **[R22][R23]**

Assessment: This is a material attribution divergence and must be represented explicitly in confidence modeling for that incident.

Activity Timeline (2009–2026)

Timeline entries are [Reported] unless explicitly marked [Assessed] or [Observed/Reported].

2009–2014 (Pre-Blackout Development Period)

- [Reported] Sandworm exploited a Windows zero-day (CVE-2014–4114) via weaponized Microsoft Office documents, affecting Windows Vista through 8.1. This was the first publicly documented Sandworm zero-day.
- [Reported] ICS-targeting preparatory activity and BlackEnergy-lineage compromise patterns observed over multi-year periods. **[R15]**
- [Reported] Unit 74455/GTsST tracked as active since at least 2009 in destructive/disruptive ecosystem context. **[R9]**

December 2015 (Ukraine Grid Disruption)

- [Assessed] Marked operational shift from intrusion to strategic critical infrastructure impact with deliberate kinetic effect.
- [Reported] BlackEnergy/KillDisk-linked disruption affecting electricity service to approximately 225,000 customers across three distribution companies. **[R4][R7][R9]**

December 2016 (Kyiv Grid / Industroyer)

- [Observed/Reported] Industroyer framework deployed for ICS protocol-level operations in electric infrastructure; linked to the Kyiv (Pivnichna substation) outage event on December 17, 2016. **[R9] [R15]**

2017 (NotPetya and BadRabbit)

- [Reported — Medium confidence] BadRabbit disruptive ransomware-style event (October 2017). The UK government profile **[R9]** includes BadRabbit in its list of Unit 74455 operations without qualification; however, independent technical corroboration across vendors (ESET, Kaspersky) remains at medium confidence, attributing it to Telebots/Sandworm. Per this document's confidence model, High confidence requires multi-source convergence across both technical and legal/government evidence. Government attribution alone does not elevate BadRabbit to High confidence; the absence of full technical convergence keeps this assessment at Medium. Treat as [Reported — Medium confidence] pending additional technical corroboration.
- [Reported] NotPetya destructive campaign launched on June 27, 2017 — timed to coincide with Ukraine's Constitution Day — with global collateral effects far beyond the initial Ukrainian theater. NotPetya was distributed via the update mechanism of M.E.Doc, a widely used Ukrainian accounting software package, enabling simultaneous delivery to all M.E.Doc users. **[R4][R6][R9]**

2018 (Olympic Destroyer and Novichok-Linked Intrusions)

- [Reported] Attempted intrusions against entities linked to Novichok investigations (OPCW/DSTL context). **[R4][R9]**
- [Reported] Olympic Destroyer operation disrupted the opening ceremony of the 2018 Pyeongchang Winter Olympics in response to Russia's doping ban, employing notable false-flag tradecraft elements designed to mislead attribution. **[R4][R8][R9]**

2019 (Georgia Defacement Campaign)

- [Reported] Large-scale disruptive defacement of approximately 15,000 Georgian websites and interruption of broadcast services attributed by UK/NCSC to GRU unit ecosystem. **[R7][R8]**

2019–2022 (Kapeka/KnuckleTouch Backdoor Development)

- [Reported] Kapeka was likely used in intrusions that led to the deployment of Prestige ransomware in late 2022, which targeted transportation and logistics companies in Ukraine and Poland. **[R27]**
- [Reported] Kapeka backdoor (tracked by Microsoft as KnuckleTouch) deployed in targeted attacks against Eastern Europe — including Ukraine and Estonia — since at least mid-2022. WithSecure attributes Kapeka to Sandworm/APT44 based on configuration and code overlaps with GreyEnergy (a

prior APT44 tool) and Prestige ransomware. Kapeka is assessed as a likely successor to GreyEnergy in Sandworm's modular espionage toolkit. **[R27]**

2021–2025 (Edge Misconfiguration-Focused Access Campaign)

- [Reported] ATI identified infrastructure overlap with "Curly COMrades" — a cluster tracked by Bitdefender employing post-exploitation techniques including Hyper-V abuse for EDR evasion and custom implants CurlyShell and CurlCat. ATI assesses these may represent complementary operations within a broader GRU campaign (one cluster focused on initial access/network pivot, the other on host-based persistence). **[R29]**
- [Reported] Amazon Threat Intelligence (ATI), published December 15, 2025, assessed with high confidence that a sustained GRU-associated campaign active since at least 2021 pivoted from vulnerability exploitation toward targeting misconfigured customer network edge devices as primary initial access vectors. The campaign targeted energy sector organizations, critical infrastructure providers, and telecom companies in North America and Europe. Assessed collection method: passive packet interception of authentication traffic on compromised devices, followed by credential replay against victim online services. **[R29]**

February 2022 (Cyclops Blink Public Exposure + Wiper Wave)

- [Reported] Microsoft documented early wartime wiper malware targeting Ukrainian organizations beginning in January 2022. **[R12]**
- [Observed/Reported] Cyclops Blink framework exposed by NCSC/CISA/NSA/FBI joint advisory as a modular SOHO/edge malware with firmware-update persistence and TLS-based C2. **[R13][R26]**

April 2022 (Industroyer2 + Multi-Wiper Attack Chain)

- [Observed/Reported] Industroyer2 attempt against a Ukrainian energy provider; companion wipers (CaddyWiper, ORCSHRED, SOLOSHRED, AWFULSHRED) deployed in coordinated fashion across Windows, Linux, and Solaris ecosystems simultaneously. **[R16][R17]**

October 2022 (MicroSCADA Native-Binary Disruption)

- [Assessed] High-signal example of OT LotL (Living-off-the-Land) execution — reducing payload footprint and accelerating operational execution against industrial targets.
- [Observed/Reported] Mandiant documented an OT disruption attempt using native MicroSCADA tooling (`scilc.exe`) and staged scripts/ISO artifacts, executed during Russia's winter military campaign of strikes against Ukraine's energy grid. **[R3]**

2022–2023 (Battlefield Intelligence and Tactical Support Expansion)

- [Reported] APT44 targeted Bellingcat and other investigative journalism entities in a phishing campaign between December 2023 and January 2024 — first public attribution of this targeting to APT44. **[R1]**
- [Reported] APT44 conducted a supply-chain attack against a software developer, resulting in the downstream compromise of critical infrastructure networks in Eastern Europe and Central Asia and the deployment of wiper malware. **[R1]**
- [Reported] APT44 targeted the drone supply chain — including manufacturing, logistics, and Ukrainian military training programs (spear-phishing campaign impersonating a drone warfare training school, exploiting CVE-2023–38831). **[R1][R28]**
- [Reported] A lethal kinetic strike on Ukraine's 128th Mountain Assault Brigade in November 2023 was traced to the penetration of a soldier's Signal account, illustrating the operational consequences of this intelligence capability. **[R28]**
- [Reported] Since at least April 2023, APT44 provisioned dedicated infrastructure and produced Russian-language instructions to enable Russian ground forces to extract Signal and Telegram communications from mobile devices captured on the battlefield. APT44 deployed the WaveSign tool — a lightweight Windows batch script — to periodically query and exfiltrate Signal messages from a victim's local Signal database. **[R1][R28]**

2022–2024 (Hacktivist-Persona Coordination Layer)

- [Reported] In March 2024, CARR claimed disruption of energy generation at a French hydroelectric facility by manipulating water levels. Verifiable causal link remains unconfirmed. **[R1]**
- [Reported] CyberArmyofRussia_Reborn (CARR) posted videos on January 17–18, 2024, claiming manipulation of HMI panels at water utilities in Poland and the United States. A U.S. local official subsequently confirmed a system malfunction causing a tank overflow at one claimed facility. Exact causal link to CARR/APT44 not fully established. **[R1]**
- [Reported] In September 2022, Mandiant initially attributed the intrusion activity supporting Telegram personas (XakNet Team, Infoccentr, CyberArmyofRussia_Reborn) to APT28, based on observed network co-habitation. In April 2024, re-analysis of the incident data allowed Mandiant to parse overlapping APT28 and APT44 activity and link the CyberArmyofRussia_Reborn-associated intrusion activity to APT44 with high confidence. Persona-level organizational affiliation with GRU remains moderate-confidence. **[R1][R25]**

2023 (Doctrine Formalization + Mobile Expansion)

- [Reported] SwiftSlicer wiper deployed against Ukrainian targets in 2023 — an additional destructive family in Sandworm's iterative wiper portfolio. **[R30]**
- [Observed/Reported] Infamous Chisel Android malware documented against Ukrainian military devices, providing Tor-backed access, modified Dropbear SSH, local network scanning, and data exfiltration of battlefield management app data. **[R14]**
- [Reported] Mandiant published the GRU disruptive playbook model: edge foothold → LotL → GPO abuse → disruptive payload → claim amplification. **[R2]**

2024 (APT44 Naming + Expanded Tooling + Telecom Disruption)

- [Reported] APT44 increasingly sourced tools and bulletproof hosting from criminal marketplaces as a disposable operational layer. **[R1]**
- [Reported] APT44 continued large-scale credential theft targeting public and private sector mail servers globally (Exim, Zimbra, Exchange), dating back to at least 2019. **[R1]**
- [Reported] APT44 has experimented with ransomware deployment against European transportation and logistics networks — an operational expansion beyond pure sabotage/espionage. **[R1]**
- [Reported] AcidPour (AcidRain variant) observed with expanded destructive capability against Linux UBI/device-mapper storage topologies; attributed to a Sandworm-linked subcluster by SentinelOne based on infrastructure overlap with the Solntsepek persona. Treat as [Reported], medium confidence. **[R19]**
- [Reported] Kapeka/KnuckleTouch formally tracked and publicly reported by WithSecure and Microsoft; attributed to APT44/Seashell Blizzard. **[R27]**
- [Reported] Mandiant formally graduated Sandworm to APT44, citing global scope and military integration across the full spectrum of espionage, attack, and influence. **[R1]**

2025 (High-Tempo Wiper Period + Edge Pivot Confirmation)

- [Reported] Amazon Threat Intelligence campaign confirmed sustained focus on edge-device targeting through end of 2025; APT44 maintained this posture while reducing N-day/zero-day exploitation investment. **[R29]**
- [Reported] Microsoft documents continued global access operations by Seashell Blizzard/BadPilot subgroup, including exploitation of U.S./UK internet-facing systems. **[R10]**
- [Reported] ESET notes UAC-0099 initial-access handoff to Sandworm for follow-on operations. **[R21]**
- [Reported] ESET reports Sandworm deployment of ZEROLOT and Sting against Ukrainian government, energy, logistics, and grain sectors. **[R20][R21]**

December 2025 — January 2026 (Poland Energy/Industrial Incident)

- [Assessed] Attribution for this incident remains contested (ESET vs. CERT Polska) and should remain medium confidence pending additional corroboration.
- [Observed/Reported] Enterprise escalation chain: LSASS dumping, NTDS.dit/SAM/SYSTEM theft, Kerberos ticket abuse (Diamond Ticket), domain-wide GPO/scheduled-task wiper rollout. **[R23]**
- [Observed/Reported] OT impact mechanics: RTU firmware sabotage (inserted bytes causing reboot loops), device-level destructive commands, attacker-performed factory reset of edge appliances to hinder restoration and erase traces. **[R23]**
- [Observed/Reported] Recurring preconditions across affected sites: FortiGate VPN exposed to the internet without MFA and extensive credential reuse risk. **[R23]**
- [Reported] ESET attributes DynoWiper to Sandworm with medium confidence and documents ZOV/DynoWiper logic overlap. **[R22]**
- [Observed/Reported] CERT Polska reports coordinated destructive attacks across more than 30 renewable energy sites, a CHP entity, and a manufacturing target; IT+OT impact attempts including firmware tampering and wiper deployment. **[R23]**

Timeline Synthesis

- [Assessed] 2025–2026 reporting indicates sustained destructive capability rather than de-escalation.
- [Assessed] Concurrent with destructive operations, APT44 has pursued a qualitative expansion into tactical battlefield support, signal intelligence collection, and criminal marketplace integration.
- [Assessed] APT44 evolved from selective high-impact bespoke attacks into repeatable, scalable disruption operations integrating edge access + privileged orchestration + rapid destructive payloading.

Confirmed vs Claimed Matrix

Each entry records the corroboration status of a significant reported operation or activity.

2015/2016 Ukraine grid disruptions

Source type: Gov/legal/vendor technical. Status: Corroborated. Evidence: Multi-source attribution; malware and protocol evidence across multiple independent investigations. Limitation: Some victim-side forensic detail remains non-public. Defensive action: Maintain OT protocol anomaly and relay analytics.

NotPetya (2017)

Source type: Gov/legal/vendor. Status: Corroborated. Evidence: Strong legal and technical convergence; DOJ indictment names responsible officers. Limitation: Global spillover complicates exact per-victim intent. Defensive action: Enforce software supply-chain trust controls.

2022 MicroSCADA native-tool disruption

Source type: Vendor technical. Status: Partially corroborated. Evidence: Procedure chain, command artifacts, OT context documented by Mandiant. Limitation: Full initial-access path not fully public. Defensive action: Monitor OT-native binary invocations.

Kapeka/KnuckleTouch deployment (2022+)

Source type: Multi-vendor (WithSecure, Microsoft). Status: Partially corroborated. Evidence: GreyEnergy and Prestige lineage overlap; victim targeting pattern. Limitation: Limited public sample set. Defensive action: Hunt for GreyEnergy-lineage backdoor TTPs.

2025 Ukraine wiper waves (ZEROLOT/Sting)

Source type: Vendor periodic APT reporting. Status: Partially corroborated. Evidence: Campaign pattern, sectors, deployment context documented by ESET. Limitation: Not all samples public. Defensive action: Strengthen wiper and AD/GPO hunting.

December 2025 Poland energy incident

Source type: CSIRT technical + vendor attribution. Status: Contested / Partially corroborated. Evidence: CERT Polska technical report and ESET DynoWiper attribution. Limitation: Inter-vendor attribution divergence (ESET attributes to Sandworm; CERT Polska notes overlap with Berserk Bear / Ghost Blizzard cluster). Defensive action: Treat TTP set as high-priority regardless of final attribution label.

Signal/Telegram battlefield interception

Source type: Multi-source (Mandiant, RUSI, NCSC, SBU). Status: Corroborated. Evidence: Infrastructure provisioned and documented, WaveSign tool technically analyzed, lethal strike case publicly reported. Limitation: Exact exfiltration volumes non-public. Defensive action: Enforce device encryption, battlefield mobile device policy.

CARR/HMI manipulation claims (2024)

Source type: Persona channels plus partial official confirmation. Status: Partially corroborated. Evidence: U.S. local official confirmed malfunction at one claimed facility; videos published by CARR. Limitation: Full

causal chain not independently verified. Defensive action: Treat exposed HMI interfaces as critical risk.

Persona-layer “success” claims (general) Source type: Persona channels and media echo. Status: Claim-heavy. Evidence: Output visibility only. Limitation: Not independently verified compromise evidence. Defensive action: Maintain claim-vs-telemetry workflow.

Targeting and Victimology

Observed targeting concentration:

- [Assessed] NATO-adjacent and global expansion: opportunistic access campaigns create latent options beyond immediate conflict zones; ATI campaign documented targeting in North America, Western Europe, Eastern Europe, and the Middle East. **[R10][R29]**
- [Reported] Democratic processes and election infrastructure: APT44 has attempted to interfere with democratic processes in multiple countries through data leaks and election system access. **[R1]**
- [Reported] Civil society, investigative journalism, and NGOs: Bellingcat, OPCW-linked entities, and similar organizations targeted for influence-related purposes. **[R1]**
- [Reported] Edge and identity control plane assets: VPN gateways, firewall management surfaces, domain controllers, and identity infrastructure repeatedly appear as decisive enabling layers. **[R10][R23][R26][R29]**
- [Reported] Logistics/transport/manufacturing/grain/drone supply chain: strategic economy pressure and operational friction; APT44 has directly targeted drone manufacturing, training, and logistics. **[R1][R10][R21]**
- [Reported] Telecommunications: disruption and intelligence leverage against communications environments, including interception of battlefield communications. **[R19][R28]**
- [Reported] Government and military-adjacent institutions: strategic state pressure, wartime support functions, battlefield command-and-control systems. **[R1][R4][R10]**
- [Reported] Energy and utilities (IT+OT): grid operations, substations, CHP, renewable interconnect points, hydroelectric facilities. **[R1][R3][R9][R23]**

Operational Doctrine: Evolution

Phase 1: Bespoke High-Impact Disruption (2015–2018)

Heavy focus on custom destructive tooling and strategic signaling events. Strong OT specialization with Industroyer-class capabilities. False-flag tradecraft deployed in Olympic Destroyer to complicate attribution.

[R9][R15]

Phase 2: Blended Sabotage + Deniability (2019–2022)

Continued destructive operations with increased use of public-facing cover narratives, hacktivist personas, and expanded edge-device persistence. [R8][R13]

Phases 3 and 4 are concurrent, not sequential — they represent parallel operational tracks from 2022 onward.

Phase 3 (Tactical): Scaled Wartime Playbook (2022–Present)

Repeatable operational cycle emphasizing speed, scalability, and survivability. As described by Mandiant [R2]:

1. Telegraphing success — persona-layer claim amplification
2. Disrupt and deny — wiper and OT payload deployment
3. Going for GPO / privileged orchestration — domain-wide reach
4. Living off the land — LotL execution with native tooling
5. Living on the edge — initial access via exposed or misconfigured edge devices

Phase 4 (Influence Layer): Distributed Amplification and Attribution Friction (2022–Present)

Persona-layer messaging assessed as coordinated or adjacent in selected cases; can increase perceived impact before forensic closure. Analysts must separate tactical defensive response (TTP-driven) from unresolved incident-level attribution disputes. [R23][R25]

Phase 5 (Battlefield Integration): Tactical Intelligence and Kinetic Support (2023–Present)

Qualitative doctrinal expansion documented in 2024 Mandiant APT44 report and RUSI analysis: direct support to Russian ground forces through Signal/Telegram exfiltration infrastructure, WaveSign tooling, drone supply-chain targeting, and battlefield management system penetration. [R1][R28]

[Assessed] The doctrinal arc runs from “single flagship capability” → “repeatable campaign system” → “integrated battlefield intelligence support service.” Each phase expands APT44’s operational mandate rather than replacing prior capabilities.

Initial Access and Privilege Escalation Patterns (Observed 2021–2026)

- [Observed/Reported] Post-compromise escalation: LSASS credential dumping, NTDS.dit/SAM/SYSTEM extraction, Kerberos ticket abuse (Diamond Ticket) to sustain privileged domain control. **[R23]**
- [Observed/Reported] CERT Polska incident: initial footholds via FortiGate VPN surfaces without MFA; account takeover and privilege escalation into AD/OT management layers. **[R23]**
- [Reported] Amazon Threat Intelligence 2025 campaign: primary initial access vector shifted to misconfigured customer network edge devices (routers, VPN concentrators, network appliances) rather than active vulnerability exploitation — passive packet interception assessed as credential collection method. **[R29]**
- [Reported] Microsoft documents BadPilot campaign exploiting vulnerabilities in ConnectWise ScreenConnect (CVE-2024-1709), Fortinet FortiClient EMS (CVE-2023-48788), Microsoft Exchange (CVE-2021-34473), Zimbra (CVE-2022-41352), WatchGuard (CVE-2022-26318), and Confluence (CVE-2021-26084, CVE-2023-22518). **[R10][R29]**

Malware and Tooling Portfolio

Each entry gives the category, name, function, earliest confirmed date in scope, and linkage confidence.

Industroyer / Industroyer2 — ICS/OT sabotage. ICS protocol modules (IEC 60870–5–101, IEC 60870–5–104, IEC 61850, OPC DA) for grid protocol abuse, plus SIPROTEC DoS module (CVE-2015–5374). Earliest confirmed: 2016 / 2022. Confidence: High.

Cyclops Blink — Edge persistence. Modular Linux ELF; firmware-update persistence; TLS-based C2 with random server fallback; process masquerading. Earliest confirmed: 2019+ (publicly exposed 2022). Confidence: High.

Kapeka / KnuckleTouch — Modular espionage backdoor. Windows DLL backdoor; GreyEnergy successor; dropper + persistence; AES-256 C2 config; credential theft; custom payload execution. Earliest confirmed: 2022+ (formally tracked 2024). Confidence: Medium-High.

WaveSign — Signal/Telegram interception. Windows batch script; periodically queries and exfiltrates Signal messages from local Signal database; used with captured battlefield devices. Earliest confirmed: 2023+. Confidence: High.

Infamous Chisel — Mobile military targeting. Android malware; Tor hidden service; modified Dropbear SSH; local network scanning; battlefield app data exfiltration. Earliest confirmed: 2023. Confidence: High.

CaddyWiper / ZEROLOT / Sting / ZOV / DynoWiper — IT destructive (fast). Rapid file/system/volume destruction; GPO-distributed. Earliest confirmed: 2022–2026. Confidence: Medium-High.

LazyWiper (KB284726.ps1) — IT destructive (slow/PS). PowerShell-based wiper; slower destruction model. Earliest confirmed: 2025. Confidence: Medium-High. **[R23]**

SwiftSlicer — IT destructive. Wiper family deployed against Ukrainian targets 2023. Earliest confirmed: 2023. Confidence: Medium-High.

AcidRain / AcidPour — Telecom/embedded destructive. Modem/storage destructive operations (AcidRain: MIPS-targeted; AcidPour: UBI/device-mapper/Linux support). Earliest confirmed: 2022 / 2024. Confidence: Medium-High.

⚠️ Attribution caveat for AcidPour: Attributed to a Sandworm-linked subcluster by SentinelOne, based on infrastructure overlap with the Solntsepek Telegram persona previously associated with APT44 operations. Treat as [Reported], medium confidence, pending independent technical corroboration. **[R19]** ⚠️ Circular citation risk: The attribution chain for AcidPour passes through a Telegram persona (Solntsepek), which per this document's methodology falls under the "Claimed" category (actor/persona assertions without sufficient independent technical corroboration). Analysts should treat this attribution with additional caution and not use it to reinforce other persona-based attributions in a circular fashion.

Prestige (+ unnamed variants) — Ransomware (experimental). Ransomware deployed against transport/logistics; Kapeka precursor operations; European transport targets 2022/2024. Earliest confirmed: 2022+. Confidence: Medium.

CurlyShell / CurlCat — Post-exploitation cluster. Custom implants; Hyper-V abuse for EDR evasion; used by Curly COMrades cluster assessed as complementary GRU campaign. Earliest confirmed: 2024+. Confidence: Medium.

GPO scripts, scheduled tasks, admin utilities, PsExec — Orchestration. Domain-scale deployment of destructive payloads. Earliest confirmed: 2022+. Confidence: High.

BlockBit command set / native RTU actions — OT destructive command abuse. Device-level destructive commands; firmware sabotage; reboot loops against RTU-facing environments. Earliest confirmed: 2025. Confidence: Medium-High.

Deep Technical Analysis of Key Families

Industroyer / Industroyer2

- [Assessed] The reduced modularity of Industroyer2 versus the original Industroyer suggests operators possessed highly specific target intelligence, reducing the need for broad protocol flexibility.

- [Observed/Reported] Industroyer2 showed more target-tailored, hardcoded behavior (reduced modularity) and was deployed in a coordinated attack chain with CaddyWiper/ORCSHRED/SOLOSHRED/AWFULSHRED. **[R16][R17]**
- [Observed/Reported] Industroyer also includes a fifth module: a Denial-of-Service tool targeting Siemens SIPROTEC 4 and Compact protective relay devices via CVE-2015–5374. The module sends a crafted 18-byte UDP packet to port 50000, placing the device into "firmware update" mode and rendering it unresponsive until manually rebooted. This directly disables substation protection functions ("Loss of Protection" impact), meaning the grid loses automatic fault isolation capability — amplifying the physical impact of the attack beyond the outage itself. SIPROTEC relays are widely deployed in substations globally. **[R15]**
- [Observed/Reported] Industroyer framework includes ICS protocol-specific modules: IEC 60870–5–101, IEC 60870–5–104, IEC 61850, and OPC DA — designed to send malicious commands directly to substation equipment over legitimate industrial protocols. **[R15]**

Full reports here:

Industroyer: Biggest threat to industrial control systems since Stuxnet

ESET has analyzed a sophisticated and extremely dangerous malware, known as Industroyer, which is designed to disrupt…

www.welivesecurity.com

Industroyer2: Industroyer reloaded

ESET researchers have responded to a cyber-incident that affected an energy provider in Ukraine and involved…

www.welivesecurity.com

Cyclops Blink

- [Assessed] Cyclops Blink materially improves long-term edge resilience compared to opportunistic one-off footholds; its firmware-persistence model is specifically designed to outlast standard incident response.
- [Observed] Module extensibility at runtime allows capability updates without full redeployment. **[R13]**

- [Observed] NCSC malware analysis describes a modular Linux ELF framework with: firmware-update persistence (survives device resets), custom C2 over TLS with random server/port fallback logic, process masquerading (`[kworker:0/1]` kernel-thread style), and iptables rule injection to open attacker-controlled ports. **[R13]**

Full report here: https://www.ncsc.gov.uk/files/Cyclops-Blink-Malware-Analysis-Report.pdf

Kapeka / KnuckleTouch

- [Assessed] Kapeka's infrequent sightings and bespoke targeting indicate deliberate conservation of an expensive custom tool — consistent with APT44's documented preference for protecting high-cost capabilities.
- [Reported] Assessed as a likely successor to GreyEnergy; GreyEnergy itself succeeded BlackEnergy in Sandworm's arsenal. This represents a documented three-generation toolchain. **[R27]**
- [Reported] Overlaps with GreyEnergy include: identical custom data-structuring algorithm for C2 traffic, DLL format with masqueraded extension, and creation of a "Microsoft" folder in the AppData path. Key differences: Kapeka uses Windows API and registry for fingerprinting (GreyEnergy used WMI); Kapeka persists C2 config in registry (GreyEnergy used on-disk file). **[R27]**
- [Reported] Kapeka is a 32-bit/64-bit Windows DLL backdoor with a self-removing dropper. Persistence is established via either a scheduled task or autorun registry key depending on privilege level. C2 configuration is AES-256-encrypted and persisted in the registry. C2 communication uses JSON. **[R27]**

Full report here:

Kapeka: A novel backdoor spotted in Eastern Europe

This report provides an in-depth technical analysis of the backdoor and its capabilities, and analyzes the connection…

labs.withsecure.com

Infamous Chisel

- [Assessed] Supports tactical intelligence collection directly relevant to battlefield decision cycles; the documented linkage to a lethal strike on Ukrainian forces illustrates concrete operational consequences. **[R14][R28]**

- [Observed] NCSC Five Eyes Malware Analysis Report documents Android malware targeting military-use devices: Tor hidden service C2, modified Dropbear SSH server, local network scanning, and timed exfiltration of battlefield management app data, Signal messages, WhatsApp data, and Starlink terminal information. **[R14]**

Full report here:

Infamous Chisel Malware Analysis Report | CISA

Infamous Chisel is a collection of components targeting Android devices. This malware is associated with Sandworm…

www.cisa.gov

WaveSign (Signal Interception Tool)

- [Assessed] Represents a purpose-built, low-complexity tool designed for rapid operational deployment at scale — consistent with APT44's pattern of maintaining simple, disposable tools alongside complex bespoke capabilities.
- [Reported] A lightweight Windows batch script used by APT44/Seashell Blizzard to periodically query the Signal desktop message database on a victim's machine and exfiltrate the most recent messages. Used in conjunction with infrastructure provisioned for Russian ground forces to exploit captured battlefield devices. **[R28]**

Full report here:

Signals of Trouble: Multiple Russia-Aligned Threat Actors Actively Targeting Signal Messenger |…

Russia state-aligned threat actors target Signal Messenger accounts used by individuals of interest to Russia's…

cloud.google.com

AcidRain / AcidPour

- [Assessed] Indicates continued investment in telecom/embedded destructive capability targeting civilian communications infrastructure.
- [Reported] AcidRain associated with the KA-SAT satellite modem disruption (February 24, 2022); AcidPour extends destructive support to UBI and device-mapper storage targets across broader Linux environments. **[R18][R19]**

Full report here:

https://www.sentinelone.com/labs/acidpour-new-embedded-wiper-variant-of-acidrain-appears-in-ukraine/

ZEROLOT / Sting / ZOV / DynoWiper / LazyWiper (2025–2026)

- [Assessed] Design philosophy prioritizes speed, broad operational effect, and GPO-scalable deployment over obfuscation depth.
- [Observed] LazyWiper (`KB284726.ps1`): PowerShell-based, slower recursive destruction model; deployed alongside DynoWiper. **[R23]**
- [Observed] CERT Polska: two-stage deployment via `dynacom_update.ps1` → `exp1.ps1` → `schtask.exe` via domain GPO. PowerShell logging suppression active. Anti-forensics: edge appliance factory resets, file deletion. **[R23]**
- [Observed/Reported] DynoWiper: selective overwrite logic (separate handling for small vs. large files for speed optimization) and forced reboot completion behavior; ZOV code similarity noted by ESET. **[R22]**
- [Reported] ESET documents repeated wiper deployment in 2025 against Ukrainian sectors. **[R20][R21][R22]**

Full report here:

ZEROLOT Analysis: Inside Sandworm's Destructive New Wiper

This blog post is a technical analysis of the ZEROLOT malware, examining its internal mechanics and destructive…

www.immersivelabs.com

BlockBit and OT Device-Level Sabotage (2025 Poland Incident)

- [Assessed] Demonstrates a practical IT-to-OT handoff: generic enterprise compromise translated into industrial operational impact via purpose-built OT sabotage commands — confirming the doctrinal

integration described in the GRU Disruptive Playbook. **[R2][R23]**

- [Observed] CERT Polska documents `blockbit` tooling used for automated destructive actions against RTU-facing environments: interface disablement, reboot commands, storage destruction calls, and corrupted firmware with inserted bytes causing persistent reboot loops. **[R23]**

Full report here:

https://cert.pl/uploads/docs/CERT_Polska_Energy_Sector_Incident_Report_2025.pdf

Detection and Response Priorities

1. Protect mobile and messaging security for sensitive personnel. Enforce Signal/Telegram device-link auditing, restrict device pairing on operational devices, and maintain battlefield mobile device policy.
2. Detect passive credential interception patterns. Audit edge devices for packet capture utilities, unexpected file writes, and authentication relay attempts following device compromise.
3. Eliminate default credentials; enforce MFA universally on edge/OT remote paths. Treat “internet-exposed + password-only authentication” as a critical-risk misconfiguration requiring immediate remediation.
4. Operate claim-vs-telemetry workflows. Treat persona narratives and hacktivist claims as early warning only; require local evidence before compromise declaration.
5. Harden the OT remote-access boundary. Explicit allowlisting for OT-native administrative binaries and argument sets; command logging on all OT management endpoints.
6. Detect destructive precursor behavior. Anti-recovery commands, high-rate file overwrite patterns, abnormal scheduled-task rollout velocity, and PowerShell logging suppression.
7. Instrument AD/GPO abuse pathways. Alert on SYSVOL modifications, GPO scheduled-task creation, and unusual domain-controller script execution. Integrate with change-management ticketing for immediate anomaly detection.
8. Control the edge attack surface. Mandatory MFA, restricted management-plane exposure, firmware integrity verification, and emergency remediation workflows for all internet-facing edge devices.

Detection Engineering Pack (SOC-Ready)

Rule 1: Edge Admin-Plane Anomaly

Data sources: Firewall/VPN/appliance logs. Logic: New admin source IP or unexpected geolocation + configuration change + no approved change ticket. Response: Lock account, isolate management interface,

snapshot current config.

Rule 2: FortiGate/VPN Credential Abuse

Data sources: Auth logs, SIEM identity correlation. Logic: Sequential login attempts across multiple sites using credential overlap patterns. Response: Force credential rotation; block external management access pending triage.

Rule 3: GPO-Based Destructive Rollout

Data sources: AD audit, Sysmon, EDR. Logic: Creation of new scheduled tasks/scripts targeting large endpoint scope within short window. Response: Disable malicious GPO; isolate domain controller if further escalation observed.

Rule 4: Domain-Controller Script Execution Anomaly

Data sources: PowerShell logs (Script Block Logging), process telemetry. Logic: Unsigned script writes to SYSVOL, startup task paths, or Default Domain Policy XML files. Response: Suspend privileged session; preserve all script artifacts for forensic analysis.

Rule 5: Wiper Overwrite Behavior Analytics

Data sources: File telemetry (EDR). Logic: Repeated partial overwrite patterns at high velocity + forced reboot scheduling. Response: Isolate affected host clusters; trigger destructive-incident IR playbook.

Rule 6: PowerShell Anti-Forensics Detection

Data sources: PowerShell ScriptBlock logs, Module logs. Logic: `Set-PSReadLineOption -HistorySaveStyle SaveNothing` or equivalent history-suppression commands on admin hosts. Response: Flag as destructive precursor; escalate to incident queue.

Rule 7: Linux Process Masquerading (Cyclops Blink Pattern)

Data sources: EDR process + path metadata. Logic: Kernel-thread-style process names (e.g., `[kworker:0/1]`) originating from user-space executables or non-kernel paths. Response: Quarantine binary; hunt for sibling deployments across estate.

Rule 8: Firewall/iptables Rule Injection

Data sources: Linux auditd, appliance command logs. Logic: Unexpected iptables rule additions opening non-standard ports; rule changes without a corresponding change ticket. Response: Rollback policy; preserve full rule-change timeline for forensic review.

Rule 9: Tor-Linked C2 from Non-Approved Assets

Data sources: DNS/proxy/firewall egress logs. Logic: Tor relay or onion-resolution indicators from server/appliance segments. Response: Temporary egress block; forensic packet retention on affected segment.

Rule 10: OT-Native Command Misuse (scilc.exe Pattern)

Data sources: OT endpoint command telemetry. Logic: `scilc.exe` invoked with non-maintenance argument sets; execution outside approved maintenance windows. Response: Immediate OT incident bridge with operations team; manual override preparation.

Rule 11: Firmware Tamper / Reset Storm

Data sources: RTU/IED logs, maintenance management systems. Logic: Clustered firmware reset or config-wipe events across multiple substations or RTUs in short time window. Response: Shift to manual operational fallback; isolate all remote management channels.

Rule 12: Mobile Tactical Exfil (Infamous Chisel / WaveSign Pattern)

Data sources: Mobile EDR/MDM, network telemetry, DNS. Logic: Tor process activity + SSH tunnel establishment + high-frequency file staging on Android/Windows endpoints; unexpected Signal database reads. Response: Device isolation; credential/session revocation; assess linked-device exposure.

Rule 13: Claim-vs-Telemetry Mismatch Queue

Data sources: TI monitoring platform + SOC SIEM. Logic: High-profile persona claim with no matching local indicators in the expected detection window. Response: Classify as unverified; continue targeted hunt; do not initiate response actions on claim alone.

Rule 14: Kerberos Ticket Forgery / Diamond Ticket Detection

Data sources: Domain controller security logs, Kerberos telemetry, EDR identity analytics. Logic: Anomalous TGT issuance patterns; unusual service-ticket lifetimes; privileged account usage inconsistent with baseline; tickets with atypical PAC attributes. Response: Revoke suspicious tickets/sessions; rotate KRBTGT (double rotation per Microsoft recommendation); isolate compromised admin endpoints.

Rule 15: NTDS/SAM/SYSTEM Theft Sequence

Data sources: DC file access logs, Sysmon (EventID 11/15), PowerShell logs. Logic: Access/copy of `NTDS.dit` + registry hive exports (`SAM` , `SYSTEM`) from unusual process ancestry (not backup agents or authorized admin tooling). Response: Immediate identity-tier incident escalation; enterprise credential reset wave; forensic preservation of all DC artifacts.

Rule 16: Edge Device Packet Capture File Detection

Data sources: EDR on network appliances, SIEM file telemetry. Logic: Creation of `.pcap` files or invocation of `tcpdump` / `tshark` equivalents on router/VPN/firewall hosts outside maintenance windows. Response: Treat as potential credential-interception staging; audit all authentication traffic through device; initiate credential rotation for all accounts transiting the device.

Wiper/OT First 30 Minutes (Defensive Mini-Playbook)

1. Preserve all edge appliance logs before attacker-initiated factory resets can complete.
2. Activate OT manual operational fallback procedures if remote management channels are compromised.
3. Trigger enterprise-wide sweep for known destructive precursor patterns (Rules 5, 6, 14, 15).
4. Separate verified impact evidence from persona/claim-layer narratives in all communications.
5. Validate immutable backup path integrity; initiate clean-room restoration protocol.
6. Freeze automated deployment channels: GPO, software distribution, patch management.
7. Preserve volatile evidence: process tree, active services, command history, network sessions.
8. Disable suspicious privileged identities and invalidate all active tokens/sessions.
9. Isolate impacted hosts/subnets and all OT remote management pathways.
10. Declare destructive incident severity and open unified command bridge (IT + OT + Comms).

Controls Mapping (NIST CSF-Lite)

Each entry maps a risk to its control, owner, SLA, and success measure.

Risk: Edge foothold persistence

Control: Management-plane isolation + MFA + firmware attestation + packet-capture file monitoring. Owner: NetSec. SLA: 14 days. Measure: Percentage of edge devices with verified firmware baseline and MFA

enforced.

Risk: Domain-wide wiper spread

Control: Tiered admin + GPO approval workflow + DC hardening. Owner: IAM/AD. SLA: 7 days. Measure: Unauthorized GPO change MTTR.

Risk: OT remote abuse

Control: OT jump-host controls + command allowlisting + maintenance-window enforcement. Owner: OT Security. SLA: 30 days. Measure: Percentage of OT admin actions that are ticket-linked.

Risk: Rapid destructive impact

Control: Immutable backups + regular restoration exercises. Owner: Infra + IR. SLA: 30 days. Measure: Recovery time objective attainment rate.

Risk: Battlefield messaging exposure

Control: Device-link auditing + mobile policy enforcement for sensitive personnel. Owner: IT Security + Ops. SLA: 14 days. Measure: Percentage of operational devices with active link audit.

Risk: Narrative pressure

Control: Evidence-gated communications runbook. Owner: Comms + Legal + IR. SLA: Immediate. Measure: Time to validated status memo.

Common Patterns and Cross-Group Correlation

Common Operational Patterns

1. [Assessed] Tactical battlefield support represents a doctrinal expansion — APT44 is no longer solely a strategic disruptor but an operational intelligence support asset for conventional forces.
2. [Assessed] Criminal ecosystem integration is an established force-multiplier — sourcing disposable tools and hosting from criminal markets reduces operational exposure and development cost.
3. [Assessed] Anti-forensics is integrated, not optional — factory resets, logging suppression, and cleanup actions are standard in documented incident chains.

4. [Assessed] Identity and edge misconfiguration are the recurring high-leverage entry points in successful destructive chains.
5. [Assessed] Narrative operations are fused with technical action to maximize psychological and political impact.
6. [Assessed] Wiper tooling is iterative, not one-off — families are renamed, retooled, and redeployed across campaigns.
7. [Assessed] OT disruption increasingly combines native tool abuse with targeted destructive payloads to reduce ICS-specific malware exposure.
8. [Assessed] Privileged AD abuse is the enterprise force multiplier for domain-wide destructive effects.
9. [Assessed] Edge footholds are strategic enablers, not merely tactical access — they enable long-dwell credential collection and later destructive staging.

Cross-Group Correlation

The December 2025 Poland incident demonstrates that destructive TTP overlap can cross historical cluster-attribution boundaries in public models. The Kapeka toolchain (BlackEnergy → GreyEnergy → Kapeka) illustrates multi-generation tool succession across nearly a decade. Analysts must keep TTP-led defensive response independent from unresolved actor-naming disputes.

Collection Gaps and Unresolved Questions

- The relationship between APT44 ransomware experiments (European transport/logistics) and broader strategic intent is underdetermined.
- The full operational scope of the WaveSign/Signal-interception program and the volume of battlefield communications successfully compromised is not publicly quantified.
- Attribution divergence in the December 2025 Poland case requires additional independent technical reconciliation.
- The current extent of dormant pre-positioning in Western critical infrastructure outside active conflict theaters remains uncertain.
- Public forensic depth is uneven across post-2024 incidents.
- The exact organizational relationship between GTsST/Unit 74455 and documented subgroups (BadPilot, Curly COMrades) is not fully characterized in public reporting.
- Full internal tasking boundaries among Russian military cyber units (Units 74455, 26165, 161) remain opaque in open sources.

Practical Defensive Actions (Next 30 Days)

1. IR tabletop: conduct a joint IT/OT destructive-scenario exercise incorporating the CERT Polska Poland incident chain — edge access → AD escalation → GPO wiper rollout → OT firmware sabotage.
2. Claim-vs-telemetry process: establish formal documented workflow separating persona/hacktivist claims from local incident evidence; enforce evidence-gated communications.
3. Battlefield mobile policy: audit Signal and Telegram device-link settings on operational devices; enforce device security policy for personnel with access to sensitive communications.
4. OT command allowlisting: document and enforce allowlisted invocation patterns for OT-native administrative binaries; instrument anomaly alerting for deviations.
5. Wiper behavior analytics: build or validate detections for fast file-overwrite patterns, anti-recovery commands, PowerShell history suppression, and forced reboot scheduling.
6. AD/GPO detection deployment: implement high-severity detection rules for SYSVOL modifications, new scheduled tasks, and Default Domain Policy changes; route to IR immediately.
7. Credential hygiene sprint: force rotation on all accounts that transit edge/VPN/OT management devices; audit for credential reuse across facilities.
8. Emergency edge device audit: inventory all internet-facing management interfaces; verify MFA enforcement; check for unexpected packet capture files; assess firmware integrity.

Appendix A: IOC Compendium (Public Reporting)

Use these IOCs for correlation and triage only, not standalone attribution.

IOC tagging model:

- `freshness_tag`: `stable_tracking` | `durable_pattern` | `maybe_expired` | `volatile`
- `evidence_tag`: `hard` | `near-hard` | `soft`

⚠️ Network IOC Shelf-Life Warning

IP addresses from incident-specific reporting (especially the December 2025 Poland incident chain) have a short operational validity window. These addresses should be considered potentially reassigned or repurposed within weeks to months of publication. Do NOT implement as long-term blocklist entries without continuous revalidation. Use for retrospective correlation and short-term triage only.

Network Indicators (December 2025 Poland Incident Chain)

`185.200.177.10` — near-hard / maybe_expired. VPN/M365 logins in incident chain. **[R23]**

`195.26.87.225` — near-hard / maybe_expired. Renewables-sector login source. **[R23]**

`146.190.211.75` — near-hard / maybe_expired. FortiGate management abuse. **[R23]**

`128.140.34.155` — near-hard / maybe_expired. FortiGate management abuse. **[R23]**

`95.85.114.66` — near-hard / maybe_expired. C2 / tool retrieval infrastructure. **[R23]**

`95.85.114.74` — near-hard / maybe_expired. C2 / tool retrieval infrastructure. **[R23]**

`31.172.71.5` — near-hard / maybe_expired. Compromised server in incident chain. **[R23]**

`31.172.71.5:50443/tcp` — near-hard / maybe_expired. Operational port. **[R23]**

`31.172.71.5:8008/tcp` — near-hard / maybe_expired. Operational port. **[R23]**

`31.172.71.5:44445/tcp` — near-hard / maybe_expired. Operational port. **[R23]**

Domain / Infrastructure Indicators

`esetsmart[.]com` — soft / volatile. ESET-impersonation phishing domain. **[R21]**

`esetscanner[.]com` — soft / volatile. ESET-impersonation phishing domain. **[R21]**

`esetremover[.]com` — soft / volatile. ESET-impersonation phishing domain. **[R21]**

`solntsepek[.]com` — soft / volatile. Persona-linked infrastructure (AcidPour context). **[R19]**

`totalcmd[.]net` — near-hard / maybe_expired. Masquerading software distribution domain. **[R23]**

`updater-file[.]xyz` — near-hard / maybe_expired. Malware/tool delivery domain. **[R23]**

Hash IOCs — SHA256 (December 2025 Poland Incident)

`8759e79cf3341406564635f3f08b2f333b0547c444735dba54ea6fce8539cf15` — `dynacom_update.ps1` (DynoWiper distribution). hard / stable_tracking. **[R23]**

`f4e9a3ddb83c53f5b7717af737ab0885abd2f1b89b2c676d3441a793f65ffaee` — `exp1.ps1` (DynoWiper distribution). hard / stable_tracking. **[R23]**

`65099f306d27c8bcdd7ba3062c012d2471812ec5e06678096394b238210f0f7c` — `Source.exe` (DynoWiper). hard / stable_tracking. **[R23]**

`835b0d87ed2d49899ab6f9479cddb8b4e03f5aeb2365c50a51f9088dcede68d5` — `dynacom_update.exe` (DynoWiper). hard / stable_tracking. **[R23]**

`60c70cdcb1e998bffed2e6e7298e1ab6bb3d90df04e437486c04e77c411cae4b` — `schtask.exe` (DynoWiper). hard / stable_tracking. **[R23]**

`d1389a1ff652f8ca5576f10e9fa2bf8e8398699ddfc87ddd3e26adb201242160` — `schtask.exe` (DynoWiper variant). hard / stable_tracking. **[R23]**

`033cb31c081ff4292f82e528f5cb78a503816462daba8cc18a6c4531009602c2` — `KB284726.ps1` (LazyWiper). hard / stable_tracking. **[R23]**

`68192ca0fde951d973eb41a07814f402f2b46e610889224bd54583d8a332a464` — Probable original DynoWiper distribution script. near-hard / stable_tracking. **[R23]**

`ba89f7ca1fdbd7f8ce5f081f393af6e95f7de473e3d6376f42f11ad58f0f75fb` — `dynacom_update.exe` (CERT Polska sample set). hard / stable_tracking. **[R23]**

`dc54d7f820f6f699ab5a976eb95d112f54b3dddde3f0097fc7322549753f7209` — `explorer.exe` (CERT Polska sample set). hard / stable_tracking. **[R23]**

Hash IOCs — SHA256 (Cyclops Blink)

`50df5734dd0c6c5983c21278f119527f9fdf6ef1d7e808a29754ebc5253e9a86` — Cyclops Blink `cpd` sample 1. hard / stable_tracking. **[R13]**

`c082a9117294fa4880d75a2625cf80f63c8bb159b54a7151553969541ac35862` — Cyclops Blink `cpd` sample 2. hard / stable_tracking. **[R13]**

Hash IOCs — SHA256 (Infamous Chisel)

`5866e1fa5e262ade874c4b869d57870a88e6a8f9d5b9c61bd5d6a323e763e021` — `killer` component. hard / stable_tracking. **[R14]**

`2d19e015412ef8f8f7932b1ad18a5992d802b5ac62e59344f3aea2e00e0804ad` — `blob` component. hard / stable_tracking. **[R14]**

`5c5323bd17fd857a0e77be4e637841dad5c4367a72ac0a64cc054f78f530ba37` — `ndbr_armv7l`. hard / stable_tracking. **[R14]**

`3cf2de421c64f57c173400b2c50bbd9e59c58b778eba2eb56482f0c54636dd29` — `ndbr_i686`. hard / stable_tracking. **[R14]**

`338f8b447c95ba1c3d8d730016f0847585a7840c0a71d5054eb51cc612f13853` — `db` (multi-call binary). hard / stable_tracking. **[R14]**

`33a2be6638be67ba9117e0ac7bad26b12adbcdf6f8556c4dc2ff3033a8cdf14f` — `td` (Tor component). hard / stable_tracking. **[R14]**

`140accb18ba9569b43b92da244929bc009c890916dd703794daf83034e349359` — `tcpdump` component. hard / stable_tracking. **[R14]**

Hash IOCs — SHA1 (Industroyer2 Attack Chain)

`fd9c17c35a68fc505235e20c6e50c622aed8dea0` — `108_100.exe` (Industroyer2). hard / stable_tracking. **[R16]**

`6fa04992c0624c7aa3ca80da6a30e6de91226a16` — `zrada.exe` (ArguePatch). hard / stable_tracking. **[R16]**

`9ce1491ce69809f92ae1fe8d4c0783bd1d11fbe7` — `pa.pay` (TailJump / encrypted chain component). near-hard / stable_tracking. **[R16]**

`0090cb4de31d2d3bca55fd4a36859921b5fc5dae` — `link.ps1` (GPO/script enumeration). near-hard / stable_tracking. **[R16]**

`d27d0b9bb57b2bab881e0efb97c740b7e81405df` — `sc.sh` (ORCSHRED). hard / stable_tracking. **[R16]**

`3cdbc19bc4f12d8d00b81380f7a2504d08074c15` — `wobf.sh` (AWFULSHRED). hard / stable_tracking. **[R16]**

`8fc7646fa14667d07e3110fe754f61a78cfde6bc` — `wsol.sh` (SOLOSHRED). hard / stable_tracking. **[R16]**

Behavioral / Procedure Indicators

🔴 HIGH PRIORITY

`scilc.exe -do ...` against SCIL script in OT environment — near-hard / durable_pattern. OT command misuse alert. **[R3]**

GPO + scheduled task wiper deployment from domain controller — near-hard / durable_pattern. Domain-wide containment workflow. **[R2][R21][R23]**

Default Domain Policy tampering (`Files.xml` , `ScheduledTasks.xml`) — near-hard / durable_pattern. Domain policy integrity check and emergency rollback. **[R23]**

`.pcap` file creation or `tcpdump` invocation on network appliance outside maintenance window — near-hard / durable_pattern. Credential interception staging. **[R29]**

Credential replay from edge device IP against M365/cloud auth endpoint — near-hard / durable_pattern. Credential harvest confirmation. **[R29]**

LSASS + `NTDS.dit` / `SAM` / `SYSTEM` extraction sequence — near-hard / durable_pattern. Identity-tier incident escalation. **[R23]**

Kerberos ticket abuse (Diamond Ticket pattern) — near-hard / durable_pattern. KDC analytics trigger. **[R23]**

Wiper logic: separate handling for small vs. large files at high velocity — near-hard / durable_pattern. Destructive pattern analytics. **[R22][R23]**

🟠 MEDIUM-HIGH PRIORITY

PowerShell history suppression (`Set-PSReadLineOption -HistorySaveStyle SaveNothing`) — near-hard / durable_pattern. Anti-forensics detection on admin hosts. **[R23]**

`[kworker:0/1]` process name from user-space executable path — near-hard / durable_pattern. Linux process masquerade analytics. **[R13]**

Factory reset / config wipe of edge appliances during attack window — soft / durable_pattern. Anti-forensics escalation. **[R23]**

Slack webhook exfiltration of script output — near-hard / durable_pattern. Webhook egress alerting and containment. **[R23]**

Signal database file (`db.sqlite` or equivalent) accessed by unexpected process — near-hard / durable_pattern. WaveSign-type activity detection. **[R28]**

Defender Usage Notes: Prioritize multi-signal correlation over standalone IOC hits. Network IOCs from incident reporting are volatile; never use as permanent blocklist entries without revalidation. Maintain separate confidence levels for cluster attribution versus incident attribution when sources diverge. Behavioral indicators carry longer useful life than network or hash IOCs.

Appendix B: ATT&CK-Oriented Mapping (Analyst View)

ATT&CK version note: Enterprise technique IDs (T####) reference MITRE ATT&CK for Enterprise; ICS technique IDs (T0###) reference MITRE ATT&CK for ICS. This mapping was prepared against ATT&CK Enterprise v16 / ATT&CK for ICS v3 (approximate, as of March 2026). Verify sub-technique IDs and names against the current ATT&CK release at time of use — names and IDs may change between versions.

T1190 — Exploit Public-Facing Application. Exploitation of internet-facing edge software and management surfaces. **[R10][R23]**

T1133 — External Remote Services. Compromise of internet-facing edge infrastructure for initial access. **[R10][R23][R29]**

T1078.003 — Valid Accounts: Local Accounts. Reuse/abuse of local credentials on edge/OT devices. **[R23]**

T1040 — Network Sniffing. Passive packet capture on compromised edge devices for credential interception. **[R14][R29]**

T1003.001 — OS Credential Dumping: LSASS Memory. Post-compromise credential harvesting for domain escalation. **[R23]**

T1003.003 — OS Credential Dumping: NTDS. Theft of `NTDS.dit` and related registry hives. **[R23]**

T1558 — Steal or Forge Kerberos Tickets (Diamond Ticket). Diamond Ticket attack: decrypts a legitimate DC-issued TGT using the KRBTGT AES256 key, modifies the PAC to elevate privileges, and re-encrypts. Distinct from T1558.001 (Golden Ticket), which forges a TGT entirely from scratch without a legitimate AS-REQ. Diamond Ticket produces a ticket appearing to originate from the DC, making it harder to detect. No dedicated ATT&CK sub-technique exists for Diamond Ticket — map to parent T1558 only; do not conflate with T1558.001. **[R23]**

T1046 — Network Service Discovery. Internal reconnaissance before destructive stage. **[R23]**

T1053.005 — Scheduled Task/Job: Scheduled Task. Wiper orchestration across domain environments. **[R21][R23]**

T1569.002 — System Services: Service Execution. Remote command execution via PsExec/service context. **[R23]**

T1484.001 — Domain Policy Modification: Group Policy. GPO-based distribution of destructive payloads. **[R2][R21][R23]**

T1195.002 — Supply Chain Compromise: Compromise Software Supply Chain. M.E.Doc update mechanism (NotPetya); software developer compromise (Eastern Europe/Central Asia wiper). **[R1][R4]**

T1542.001 — Pre-OS Boot: System Firmware. Cyclops Blink persistence across firmware updates. **[R13]**

T1036.005 — Masquerading: Match Legitimate Name/Location. `[kworker:*]` process-style kernel-thread disguise. **[R13]**

T1562.004 — Impair Defenses: Disable/Modify Firewall. Edge firewall iptables rule injection. **[R13]**

T1562.001 — Impair Defenses: Disable or Modify Tools. Security control disruption during destructive operations. **[R23]**

T1562.013 — Impair Defenses: Disable or Modify Network Device Firewall. FortiGate configuration modification for persistence. **[R23]**

T1059.001 — Command and Scripting Interpreter: PowerShell. PowerShell-based wiper delivery and anti-forensics. **[R23]**

T1222 — File and Directory Permissions Modification. Wiper-driven permission changes. **[R23]**

T1070.004 — Indicator Removal: File Deletion. Cleanup/deletion by destructive scripts. **[R23]**

T1071.001 — Application Layer Protocol: Web Protocols. HTTP/HTTPS C2 transport. **[R13][R14]**

T1573.002 — Encrypted Channel: Asymmetric Crypto. Cyclops Blink per-message TLS encryption; Kapeka AES-256 C2. **[R13][R27]**

T1105 — Ingress Tool Transfer. Script and binary staging chain (`.ps1` → executable). **[R23]**

T1602.002 — Data from Configuration Repository: Network Device Configuration Dump. Firewall/network config theft. **[R23]**

T1090 — Proxy. Reverse proxy and SOCKS/Tor relay in incident chains. **[R23]**

T1665 — Hide Infrastructure. Compromised infrastructure for attacker communications. **[R23]**

T1567.004 — Exfiltration Over Web Service: Exfiltration Over Webhook. Script output exfiltrated to Slack webhook. **[R23]**

T1485 — Data Destruction. Wiper family operations across campaigns. **[R16][R21][R22][R23]**

T1561.002 — Disk Wipe: Disk Structure Wipe. RAID/config destructive modification. **[R23]**

T1490 — Inhibit System Recovery. Anti-recovery behavior in destructive workflows. **[R2][R11]**

T1529 — System Shutdown/Reboot. Forced restart to complete wiper destruction. **[R22][R23]**

T1486 — Data Encrypted for Impact. Prestige ransomware deployment against transport/logistics. **[R1][R27]**

T0807 — (ICS) Command-Line Interface. OT command execution against industrial components. **[R3][R23]**

T0822 — (ICS) External Remote Services. Edge-to-OT access pathway in energy incidents. **[R23]**

T0835 — (ICS) Denial of Service. Industroyer SIPROTEC DoS module: crafted UDP packet to port 50000 triggers firmware-update mode on Siemens SIPROTEC 4/Compact relay devices (CVE-2015–5374), disabling protective relay function (Loss of Protection) until manual reboot. **[R15]**

T0839 — (ICS) Module Firmware. RTU firmware corruption (inserted bytes causing reboot loops). **[R23]**

T0886 — (ICS) Remote Services. Connection to industrial automation and RTU devices. **[R23]**

References

[R1] Google Cloud / Mandiant. Unearthing APT44: Russia's Notorious Cyber Sabotage Unit Sandworm. Published: April 17, 2024. Accessed: March 6, 2026. https://cloud.google.com/blog/topics/threat-intelligence/apt44-unearthing-sandworm

[R2] Google Cloud / Mandiant. The GRU's Disruptive Playbook. Published: July 2023 (updated attribution note April 2024). Accessed: March 6, 2026. https://cloud.google.com/blog/topics/threat-intelligence/gru-disruptive-playbook/

[R3] Google Cloud / Mandiant. Sandworm Disrupts Power in Ukraine Using a Novel Attack Against Operational Technology. Published: November 9, 2023. Accessed: March 6, 2026. https://cloud.google.com/blog/topics/threat-intelligence/sandworm-disrupts-power-ukraine-operational-technology

[R4] U.S. Department of Justice. Six Russian GRU Officers Charged in Connection with Worldwide Deployment of Destructive Malware and Other Disruptive Actions in Cyberspace. Published: October 19, 2020. Accessed: March 6, 2026. https://www.justice.gov/opa/pr/six-russian-gru-officers-charged-connection-worldwide-deployment-destructive-malware-and

[R5] U.S. Department of Justice. Remarks by Assistant Attorney General John C. Demers on Charges Against Russian Military Intelligence Officers. Published: October 2020. Accessed: March 6, 2026. https://www.justice.gov/opa/speech/remarks-assistant-attorney-general-national-security-john-c-demers-announcement-charges

[R6] GOV.UK / NCSC. Foreign Office Minister condemns Russia for NotPetya attacks. Published: February 15, 2018. Accessed: March 6, 2026. https://www.gov.uk/government/news/foreign-office-minister-condemns-russia-for-notpetya-attacks

[R7] GOV.UK / NCSC. UK condemns Russia's GRU over Georgia cyber-attacks. Published: February 20, 2020. Accessed: March 6, 2026. https://www.gov.uk/government/news/uk-condemns-russias-gru-over-georgia-cyber-attacks

[R8] GOV.UK. UK exposes series of Russian cyber attacks against Olympic and Paralympic Games. Published: October 19, 2020. Accessed: March 6, 2026. https://www.gov.uk/government/news/uk-exposes-series-of-russian-cyber-attacks-against-olympic-and-paralympic-games

[R9] GOV.UK. Profile: GRU cyber and hybrid threat operations. Published: July 18, 2025. Updated: December 4, 2025. Accessed: March 6, 2026. https://www.gov.uk/government/publications/profile-gru-cyber-and-hybrid-threat-operations/profile-gru-cyber-and-hybrid-threat-operations

[R10] Microsoft Security Blog. The BadPilot campaign: Seashell Blizzard subgroup conducts multiyear global access operation. Published: February 12, 2025. Accessed: March 6, 2026. https://www.microsoft.com/en-us/security/blog/2025/02/12/the-badpilot-campaign-seashell-blizzard-subgroup-conducts-multiyear-global-access-operation/

[R11] Microsoft MSRC. Cyber threat activity in Ukraine: analysis and resources. Published: February 2022 (living update model). Accessed: March 6, 2026. https://www.microsoft.com/en-us/msrc/blog/2022/02/analysis-resources-cyber-threat-activity-ukraine/

[R12] Microsoft Security Blog. Destructive malware targeting Ukrainian organizations. Published: January 15, 2022. Accessed: March 6, 2026. https://www.microsoft.com/en-us/security/blog/2022/01/15/destructive-malware-targeting-ukrainian-organizations/

[R13] NCSC (UK). Malware Analysis Report: Cyclops Blink. Published: February 23, 2022. Accessed: March 6, 2026. https://www.ncsc.gov.uk/files/Cyclops-Blink-Malware-Analysis-Report.pdf

[R14] NCSC (Five Eyes partners). Malware Analysis Report: Infamous Chisel. Published: August 31, 2023. Accessed: March 6, 2026. https://www.ncsc.gov.uk/static-assets/documents/malware-analysis-reports/infamous-chisel/NCSC-MAR-Infamous-Chisel.pdf

[R15] ESET. Industroyer: Biggest threat to industrial control systems since Stuxnet. Published: June 12, 2017. Accessed: March 6, 2026. https://www.welivesecurity.com/2017/06/12/industroyer-biggest-threat-industrial-control-systems-since-stuxnet/

[R16] ESET. Industroyer2: Industroyer reloaded. Published: April 12, 2022. Accessed: March 6, 2026. https://www.welivesecurity.com/2022/04/12/industroyer2-industroyer-reloaded/

[R17] ESET. Sandworm uses a new version of ArguePatch to attack targets in Ukraine. Published: May 20, 2022. Accessed: March 6, 2026. https://www.welivesecurity.com/2022/05/20/sandworm-ukraine-new-version-arguepatch-malware-loader/

[R18] SentinelOne. AcidRain | A Modem Wiper Rains Down on Europe. Published: March 31, 2022. Accessed: March 6, 2026. https://www.sentinelone.com/labs/acidrain-a-modem-wiper-rains-down-on-europe/

[R19] SentinelOne. AcidPour | New Embedded Wiper Variant of AcidRain Appears in Ukraine. Published: March 21, 2024. Accessed: March 6, 2026. https://www.sentinelone.com/labs/acidpour-new-embedded-wiper-variant-of-acidrain-appears-in-ukraine/

[R20] ESET. ESET Research APT Report: Russian cyberattacks in Ukraine intensify; Sandworm unleashes new destructive wiper. Published: May 19, 2025. Accessed: March 6, 2026. https://www.eset.com/us/about/newsroom/research/eset-research-apt-report-russian-cyberattacks-in-ukraine-intensify-sandworm-unleashes-new-destructive-wiper/

[R21] ESET. APT Activity Report (April 2025 — September 2025). Published: October 2025 (exact date unverified; reporting period April–September 2025 is inconsistent with an August publication date; treat as H2 2025 ESET APT Activity Report — verify against ESET source). Accessed: March 6, 2026. https://web-assets.eset.com/fileadmin/ESET/IT_2/eset-apt-activity-report-q2-2025-q3-2025.pdf

[R22] ESET. DynoWiper update: Technical analysis and attribution. Published: January 30, 2026. Accessed: March 6, 2026. https://www.welivesecurity.com/en/eset-research/dynowiper-update-technical-analysis-attribution/

[R23] CERT Polska. Energy Sector Incident Report — 29 December 2025. Published: January 30, 2026. Accessed: March 6, 2026. https://cert.pl/en/posts/2026/01/incident-report-energy-sector-2025/ https://cert.pl/uploads/docs/CERT_Polska_Energy_Sector_Incident_Report_2025.pdf

[R24] Microsoft Learn. How Microsoft names threat actors (alias context for Seashell Blizzard/APT44 naming). Accessed: March 6, 2026. https://learn.microsoft.com/en-us/unified-secops/microsoft-threat-actor-naming

[R25] Google Cloud / Mandiant. ‘Hacktivists Collaborate with GRU-sponsored APT28’ [original title, September 2022]. April 2024 update re-attributed the supporting intrusion cluster (UNC3810) from APT28 to APT44 after re-analysis of overlapping incident data; persona-level formal affiliation with GRU operators remains moderate-confidence. Accessed: March 6, 2026. https://cloud.google.com/blog/topics/threat-intelligence/gru-rise-telegram-minions

[R26] CISA / NSA / FBI / UK NCSC and partners. AA22–054A: New Sandworm Malware Cyclops Blink Replaces VPNFilter (joint cybersecurity advisory). Published: February 23, 2022. Accessed: March 6, 2026. https://www.cisa.gov/news-events/cybersecurity-advisories/aa22-054a https://www.cisa.gov/sites/default/files/publications/AA22-054A%20New%20Sandworm%20Malware%20Cyclops%20Blink%20Replaces%20VPN%20Filter.pdf

[R27] WithSecure Labs. Kapeka: A novel backdoor spotted in Eastern Europe. Published: April 17, 2024. Accessed: March 6, 2026. https://labs.withsecure.com/publications/kapeka(Note: Microsoft tracks the same malware as KnuckleTouch; attributed to Seashell Blizzard/APT44 independently by both vendors.)

[R28] Dan Black / Royal United Services Institute (RUSI). Russia's Cyber Campaign Shifts to Ukraine's Frontlines. Published: 2024. Accessed: March 6, 2026. https://www.rusi.org/explore-our-research/publications/commentary/russias-cyber-campaign-shifts-ukraines-frontlines(WaveSign tool and battlefield Signal/Telegram interception doctrine also described in Computer Weekly reporting: https://www.computerweekly.com/news/366619473/Warning-over-privacy-of-encrypted-messages-as-Russia-targets-Signal-Messenger)

[R29] Amazon Web Services / Amazon Threat Intelligence. Amazon Threat Intelligence identifies Russian cyber threat group targeting Western critical infrastructure. Published: December 15, 2025. Accessed: March 6, 2026. https://aws.amazon.com/blogs/security/amazon-threat-intelligence-identifies-russian-cyber-threat-group-targeting-western-critical-infrastructure/(Assessed with high confidence as associated with Sandworm/APT44/Seashell Blizzard based on infrastructure overlaps in Amazon telemetry; also references Curly COMrades / Bitdefender CurlyShell/CurlCat cluster.)

[R30] ESET / Picus Security (corroborating). SwiftSlicer wiper. First documented: January 2023. Accessed: March 6, 2026. (SwiftSlicer referenced in multiple open-source APT44/Sandworm wiper campaign surveys, including ESET periodic reporting and Picus Security's Sandworm profile: https://www.picussecurity.com/resource/blog/inside-sandworm-decade-of-cyber-sabotage-and-espionage-activity)

Andrey Pautov

Cyber Threat Intelligence

Cybersecurity

Hacker

Apt

Sandworm

↑ Table of Contents · ↑ Top